

Индивидуальный проект

Этап №5

Сергеев Даниил Олегович

2026-05-16

Содержание I

- 1 Информация
- 2 Цель работы
- 3 Ход выполнения лабораторной работы
- 4 Выводы

Раздел 1

Информация

- Сергеев Даниил Олегович

- Сергеев Даниил Олегович
- Студент

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика
- Российский университет дружбы народов

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика
- Российский университет дружбы народов
- 1132246837@pfur.ru

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика
- Российский университет дружбы народов
- 1132246837@pfur.ru
- <https://github.com/FrigatZero>

Раздел 2

Цель работы

Цель работы

Целью данной работы является использование приложения BurpSuite в рамках индивидуального проекта.

Раздел 3

Ход выполнения лабораторной работы

Ход выполнения лабораторной работы

Будем тестировать BurpSuite на основе DVWA, установленного на прошлых этапах. Запустим веб-приложение и BurpSuite.

```
service apache2 start  
service mariadb start
```

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения.

Ход выполнения лабораторной работы

The screenshot displays the Burp Suite Community Edition v2025.10.6 interface. The main window is titled 'Burp Suite Community Edition v2025.10.6 - Temporary Project'. The top menu bar includes 'Burp', 'Project', 'Intruder', 'Repeater', 'View', and 'Help'. The top toolbar contains 'Dashboard', 'Target', 'Proxy', 'Intruder', 'Repeater', 'Collaborator', 'Sequencer', 'Decoder', 'Comparer', 'Logger', 'Organizer', 'Extensions', and 'Learn'. The left sidebar shows the 'Tasks' panel with a 'New live task' button and a search bar. The main panel displays the configuration for a task named '1. Live passive crawl from Proxy (all traffic)'. The task is currently in the 'Summary' view. The 'Task configuration' section shows the following settings: Task type: Live passive crawl, Scope: Proxy (all traffic), Configuration: Add links. Add item itself, same domain and URLs in suite scope, and Capturing: ☒. The 'Task progress' section shows: Site map items added: 0, Responses processed: 0, and Responses queued: 0. The 'Task log' section is empty. The main content area shows a table titled 'Items added to site map' with columns: Host, Method, URL, Status code, and MIME type. The table is currently empty, and a message states: 'No items to show. Items found in the crawl will display here.'

Burp Suite Community Edition v2025.10.6 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Tasks New scan New live task

Filter Search

1. Live passive crawl from Proxy (all traffic)

Add links. Add item itself, same domain and URLs in suite scope.

Capturing ☒

Summary

Items added to site map View site map

Host	Method	URL	Status code	MIME type
------	--------	-----	-------------	-----------

No items to show

Items found in the crawl will display here.

Task configuration

Task type: Live passive crawl

Scope: Proxy (all traffic)

Configuration: Add links. Add item itself, same domain and URLs in suite scope

Capturing ☒

Task progress

Site map items added: 0

Responses processed: 0

Responses queued: 0

Task log

Ход выполнения лабораторной работы

Откроем вкладку Proxu и включим перехват запросов (Intercept on) и откроем браузер через приложение (если открыть браузер через BurpSuite, то он автоматически настроит подключение к прокси-серверу). Попробуем посетить целевой сайт `localhost/DVWA`. Если мы будем просто ждать, то страница не загрузится, из-за того, что BurpSuite перехватил запрос. Откроем Proxu и посмотрим, приложение определило.

Ход выполнения лабораторной работы

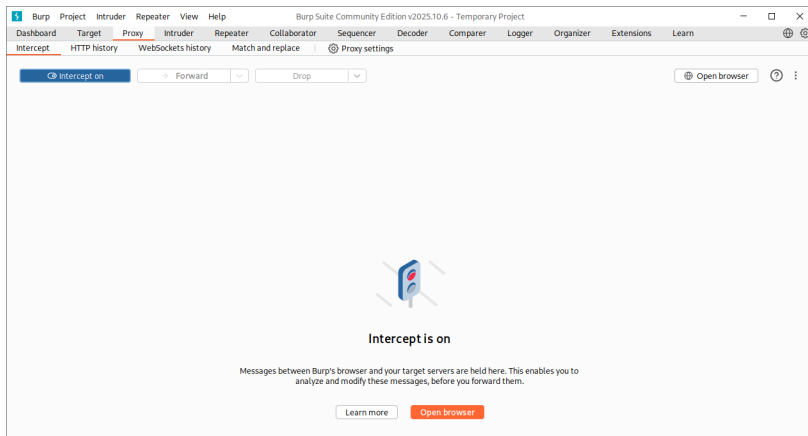


Рисунок 2: Вкладка Proxy

Ход выполнения лабораторной работы

The screenshot displays the Burp Suite interface. The top menu bar includes Burp, Project, Intruder, Repeater, View, and Help. The main toolbar shows various tools like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The Proxy tab is active, showing a list of intercepted requests. The first request is highlighted, showing its details in the Request and Inspector panels.

Request

Time	Type	Direction	Method	URL	Status code	Length
18:25:53.1...	HTTP	→ Request	GET	https://www.google.com/warmup.html		
18:26:29.1...	HTTP	→ Request	GET	http://localhost/DVWA/		

Request Details (Pretty view):

```
1 GET /warmup.html HTTP/1.1
2 Host: www.google.com
3 Sec-Ch-Ua: "Not_A_Brand";v="99", "Chromium";v="142"
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
9 Sec-Purpose: prefetch;prerender
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 X-Client-Data: COP9ygE=
12 Sec-Fetch-Site: none
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18 Connection: keep-alive
```

Inspector

Request attributes	2
Request query parameters	0
Request body parameters	0
Request cookies	0
Request headers	17

Рисунок 3: Перехваченный запрос

Ход выполнения лабораторной работы

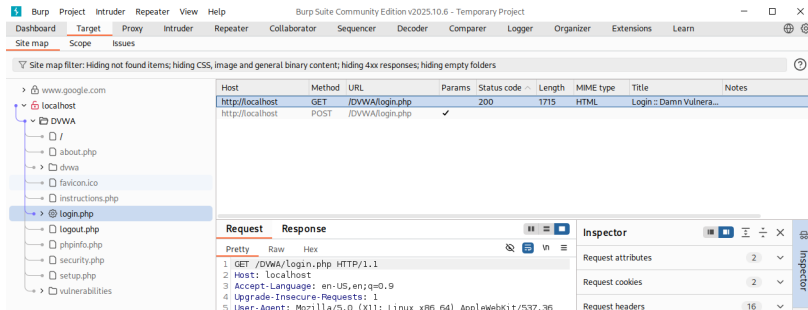


Рисунок 4: Вкладка Target

Вернемся на страницу и попробуем сгенерировать трафик, которым воспользуется нарушитель в лице BurpSuite. Заполним в форме входа случайные данные и отправим POST запрос.

Ход выполнения лабораторной работы

Request

```
1 POST /DVWA/login.php HTTP/1.1
2 Host: localhost
3 Content-Length: 83
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not_A_Brand";v="99", "Chromium";v="142"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://localhost
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
13 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: http://localhost/DVWA/login.php
19 Accept-Encoding: gzip, deflate, br
20 Cookie: PHPSESSID=d56fde445bba575ed81d92652ca0e02f; security=low
21 Connection: keep-alive
22
23 username=user&password=1234&Login=Login&user_token=08c3b19addc548b02699db2c5363db3
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 4
- Request cookies: 2
- Request headers: 20

Рисунок 5: Перехват POST запроса

Ход выполнения лабораторной работы

1 2 3 x +

Cluster bomb attack Start attack

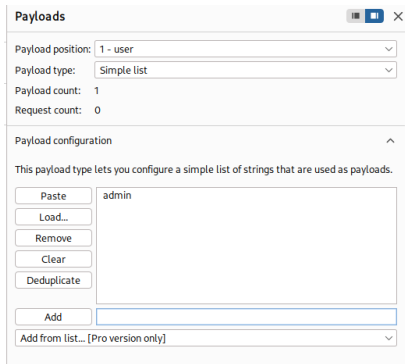
Target http://localhost Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
1 POST /DWA/login.php HTTP/1.1
2 Host: localhost
3 Content-Length: 83
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not_A_Brand";v="99", "Chromium";v="142"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://localhost
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
13 Chrome/142.0.0.0 Safari/537.36
14 Accept:
15 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/a
16 png,*/q=0.8,application/signed-exchange;v=b3;q=0.7
17 Sec-Fetch-Site: same-origin
18 Sec-Fetch-Mode: navigate
19 Sec-Fetch-User: ?1
20 Sec-Fetch-Dest: document
21 Referer: http://localhost/DWA/login.php
22 Accept-Encoding: gzip, deflate, br
23 Cookie: PHPSESSID=d56fde445bba575ed81d92652ca0e02f; security=low
24 Connection: keep-alive
25
26 username=$user5&password=$12345&Login=Login&user_token=
```

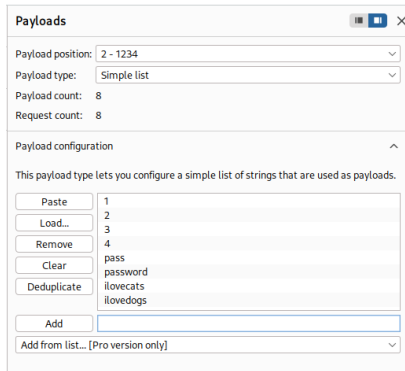
Ход выполнения лабораторной работы

Теперь в меню полезных нагрузок Payloads укажем данные для перебора, а именно: имя пользователя (1) и пароль (2).



The screenshot shows the 'Payloads' configuration window. The 'Payload position' is set to '1 - user'. The 'Payload type' is 'Simple list'. The 'Payload count' is 1 and the 'Request count' is 0. Under 'Payload configuration', there is a text area containing the word 'admin'. To the left of the text area are buttons: 'Paste', 'Load...', 'Remove', 'Clear', 'Deduplicate', and 'Add'. At the bottom, there is an 'Add from list... [Pro version only]' dropdown menu.

Рисунок 7: Имена пользователя для перебора



The screenshot shows the 'Payloads' configuration window. The 'Payload position' is set to '2 - 1234'. The 'Payload type' is 'Simple list'. The 'Payload count' is 8 and the 'Request count' is 8. Under 'Payload configuration', there is a list of passwords: '1', '2', '3', '4', 'pass', 'password', 'ilovecats', and 'ilovedogs'. To the left of the list are buttons: 'Paste', 'Load...', 'Remove', 'Clear', 'Deduplicate', and 'Add'. At the bottom, there is an 'Add from list... [Pro version only]' dropdown menu.

Рисунок 8: Пароли для перебора

Ход выполнения лабораторной работы

Запустим атаку и посмотрим результаты перебора. Мы можем заметить, что все запросы имеют статус 302 - перенаправление. При неудачной попытке, страница перекидывает нас на форму входа `login.php`, а при удачной - на страницу `index.php`.

Ход выполнения лабораторной работы

2. Intruder attack of http://localhost

Attack ▾ Save ▾

Results Positions

▼ Capture filter: Capturing all items ☐ Apply capture filter

▼ View filter: Showing all items ⋮

Request ^	Payload 1	Payload 2	Status code	Response re...	Error	Timeout	Length	Comment
0			302	44			455	
1	admin	1	302	1			454	
2	admin	2	302	2			455	
3	admin	3	302	3			454	
4	admin	4	302	4			455	
5	admin	pass	302	2			454	
6	admin	password	302	2			455	
7	admin	ilovecats	302	2			454	
8	admin	ilovedogs	302	29			455	

Рисунок 9: Результат перебора

Ход выполнения лабораторной работы



Рисунок 10: Информация об ответе

Ход выполнения лабораторной работы

Передадим тело POST запроса в Repeater. Здесь мы можем поменять пароль и имя пользователя на правильные и совершить редирект. После этого мы получим ответ в поле Response. Там же мы можем предварительно посмотреть на то, как будет выглядеть страница.

Ход выполнения лабораторной работы

The screenshot displays the Burp Suite Repeater interface. The top menu bar includes Burp, Project, Intruder, Repeater, View, and Help. The main toolbar shows various tools like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The Repeater tab is active, showing a list of requests. The selected request is a POST to /DWA/login.php with a body containing login credentials. The response is a 200 OK status with a 302 Found redirect. The Inspector panel on the right shows the details of the response, including headers and cookies.

Request

```
1 POST /DWA/login.php HTTP/1.1
2 Host: localhost
3 Content-Length: 88
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not_A Brand";v="99",
  'Chromium';v="142"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://localhost
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/142.0.0.0 Safari/537.36
13 Accept:
  text/html,application/xhtml+xml,application/xml;q=
  0.9,image/avif,image/webp,image/apng,*/*;q=0.8,app
  lication/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: http://localhost/DWA/login.php
19 Accept-Encoding: gzip, deflate, br
20 Cookie: PHPSESSID=d56fde445bba575ed81d92652ca0e02f
  ; security=low
21 Connection: keep-alive
22
23 username=admin&password=password&Login=Login&
  user_token=08c3b19addc548b02698dbe2c5363db3
```

Response

```
1 HTTP/1.1 302 Found
2 Date: Sat, 16 May 2026 15:33:27 GMT
3 Server: Apache/2.4.65 (Debian)
4 Set-Cookie: PHPSESSID=
  d56fde445bba575ed81d92652ca0e02f; expires=Sun, 17
  May 2026 15:33:27 GMT; Max-Age=86400; path=/
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate
7 Pragma: no-cache
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 4
- Request cookies: 2
- Request headers: 20
- Response headers: 11

Рисунок 11: Ответ в Repeater

Ход выполнения лабораторной работы

Send  Cancel < >  Burp AI

Request

Pretty Raw Hex   

```
1 GET /DVWA/index.php HTTP/1.1
2 Host: localhost
3 Cache-Control: max-age=0
4 sec-ch-ua: "Not_A Brand";v="99",
  "Chromium";v="142"
5 sec-ch-ua-mobile: ?0
6 sec-ch-ua-platform: "Linux"
7 Accept-Language: en-US,en;q=0.9
8 Origin: http://localhost
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/142.0.0.0 Safari/537.36
11 Accept:
  text/html,application/xhtml+xml,application/xml;q=
  0.9,image/avif,image/webp,image/apng,*/*;q=0.8,app
  lication/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer: http://localhost/DVWA/login.php
17 Accept-Encoding: gzip, deflate, br
18 Cookie: PHPSESSID=d56fde445bba575ed81d92652ca0e02f
  ; security=low
19 Connection: keep-alive
20
21
```

Response

Pretty Raw Hex Render   



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Welcome to I

Damn Vulnerable Web Appli goal is to be an aid for secur developers better understand learn about web application

The aim of DVWA is to **prac difficulty**, with a simple str

General Instruct

It is up to the user how they selecting any module and w is not a fixed object to comp system as best as they poss

Please note, there are **both** intentional. You are encoura

There is a help button at the There are also additional lin

WARNING!

Damn Vulnerable Web Appli folder or any Internet facir (such as [VirtualBox](#) or [VMware](#))

Раздел 4

Выводы

В результате выполнения лабораторной работы я испытал набор инструментов безопасности веб-приложений BurpSuite и узнал как с помощью него можно совершить атаку Cluster bomb на незащищенный сайт.